

SYNTHÈSE DE L'AUDIT DE SÉCURITÉ APPLICATIVE

Application :	Système de gestion des accès (Badges, Personnes, Clés, Trousseaux)
Environnement :	Local (PHP natif avec persistance PDO / MySQL)
Outil d'audit :	OWASP ZAP v2.17.0 (Dynamic Application Security Testing - DAST)
Date du scan :	11 juin 2026 à 15:51

1. Synthèse Numérique des Alertes

Le scan actif et passif mené par l'outil OWASP ZAP a permis de cartographier l'application et d'analyser son comportement face aux vecteurs d'attaque automatisés. Le tableau ci-dessous résume les alertes levées par niveau de criticité :

NIVEAU DE RISQUE	NOMBRE D'ALERTES	IMPACT SUR L'APPLICATION
ÉLEVÉ (HIGH)	0	Aucune faille majeure (injection SQL critique, exécution de code à distance) détectée.
MOYEN (MEDIUM)	4	Risques d'usurpation de requêtes (CSRF), d'exposition de l'arborescence ou d'intégration malveillante.
FAIBLE (LOW)	4	Manque de durcissement des en-têtes HTTP de sécurité et fuites mineures d'informations contextuelles.
INFORMATION	2	Éléments contextuels concernant les serveurs et la structure HTML.

2. Analyse Détaillée et Plan d'Action Technologique

Cette section détaille les vulnérabilités identifiées dans le périmètre du projet, ainsi que les correctifs PHP concrets à implémenter avant le déploiement de l'application.

Absence de jetons anti-CSRF (Cross-Site Request Forgery)

MOYEN

Cible principale : `http://localhost/stage/personnes.php` (CWE-352)

Description : Les formulaires d'action (enregistrement de personnes, clés, badges) ne disposent pas de mécanisme de vérification d'intention. Un attaquant pourrait forcer un utilisateur légitime à soumettre des requêtes HTTP malveillantes à son insu.

Remédiation : Générer un jeton cryptographique en session et le valider lors de chaque soumission POST.

```
// 1. Génération dans le formulaire
if (session_status() === PHP_SESSION_NONE) session_start();
if (empty($_SESSION['csrf_token'])) {
    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
}
// Dans le HTML : <input type="hidden" name="csrf_token" value="php echo
$_SESSION['csrf_token']; ?">

// 2. Vérification lors de la réception du POST
if (!hash_equals($_SESSION['csrf_token'], $_POST['csrf_token'])) {
    die("Erreur : Action non autorisée.");
}
```

Exploration de répertoire activée (Directory Listing)

MOYEN

Cible : `http://localhost/stage/assets/css/` (CWE-548)

Description : En l'absence de fichier d'index, le serveur web liste publiquement le contenu des dossiers d'assets, exposant la structure technique et l'ensemble des fichiers sous-jacents.

Remédiation : Ajouter un fichier `index.php` ou `index.html` vide dans chaque sous-répertoire sensible pour interdire la navigation visuelle, ou désactiver le listing via la configuration du serveur (Options -Indexes dans un fichier `.htaccess` Apache).

Absence d'en-têtes de protection (CSP & Anti-Clickjacking)

MOYEN

Cible : Global / index.php (CWE-693)

Description : L'application n'indique pas au navigateur les restrictions sur les sources d'exécution des scripts ni les règles de mise en conformité au sein d'éléments tiers (iframe), facilitant le détournement de clics.

Remédiation : Injecter les directives de sécurité via les en-têtes HTTP natifs de PHP.

```
<?php
header("Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self';");
header("X-Frame-Options: DENY");
header("X-Content-Type-Options: nosniff");
?>
```

Redirection volumineuse sans rupture d'exécution (Big Redirect)

FAIBLE

Cible : POST http://localhost/stage/fiche_trousseau.php

Description : Lors d'une redirection HTTP (code 302), le script PHP continue de s'exécuter en arrière-plan et de délivrer du contenu textuel. Cela peut provoquer des fuites d'informations si la logique métier n'est pas explicitement interrompue.

Remédiation : Ajouter systématiquement l'instruction `exit` ; immédiatement après l'envoi de l'en-tête de redirection.

```
header("Location: fiche_trousseau.php?id=" . $id);
exit; // Interrompt immédiatement l'exécution du script PHP
```

Attribut HTML contrôlable par l'utilisateur (Risque XSS potentiel)

INFO

Cible : Formulaire trousseaux.php (CWE-20)

Description : ZAP a identifié que certaines valeurs soumises par le biais des formulaires sont réinjectées au sein des attributs HTML (ex : persistance de la saisie dans l'attribut `value` d'un `input`). Sans nettoyage, un attaquant pourrait briser la balise et insérer du JavaScript malveillant.

Remédiation : Encapsuler systématiquement les variables dynamiques réaffichées dans la fonction PHP `htmlspecialchars()`.

3. Conclusion et Bilan de ma Démarche de Sécurité

Mon bilan personnel

L'intégration de l'outil OWASP ZAP dans mon cycle de développement m'a permis d'adopter une démarche proactive de sécurité (DevSecOps) sur mon application [cite: 4]. Les résultats de ce scan valident en premier lieu mes choix d'architecture : l'utilisation systématique de **PDO** avec des requêtes préparées a pleinement porté ses fruits, car aucune faille d'injection SQL critique n'a été détectée sur mes formulaires de gestion de badges et de clés [cite: 4].

Les vulnérabilités qui sont ressorties du rapport (comme l'absence de jeton CSRF ou le directory listing) ne remettent pas en cause la structure de ma base de données, mais relèvent plutôt du durcissement périphérique de mon code [cite: 4].

Mes prochaines étapes

Ce travail d'audit m'a fait prendre conscience de l'importance de ne pas me focaliser uniquement sur la logique métier PHP, mais aussi sur la sécurité des échanges entre le navigateur et le serveur [cite: 4]. Pour finaliser mon application avant son déploiement, je vais appliquer les actions suivantes [cite: 4] :

1. Sécuriser mon formulaire personnes.php en y implémentant les jetons CSRF générés par session [cite: 4].
2. Ajouter des en-têtes HTTP de sécurité (X-Frame-Options, nosniff) pour protéger l'application contre le vol de clics [cite: 4].
3. Bloquer l'exploration de mes répertoires d'assets via mon serveur local [cite: 4].

Grâce à cette démarche, j'ai pu élever le niveau de sécurité global de mon projet tout en développant mes compétences pratiques en cybersécurité applicative [cite: 4].